

Web-Security und Intrusion Prevention

SoSe 26

Prof. R. Zahoransky

Hochschule Furtwangen (University of Applied Science)

Aufgabenblatt 4 Broken Access Control

Lernziele: Broken Access Schwachstellen aufzeigen und verhindern

Abgabetermin wird bekannt gegeben

Aufgabe 1: Verstehen der Webanwendung

Die Webseite, die Sie gleich starten ist in PHP geschrieben, einer weit verbreiteten Programmiersprache in der Webentwicklung. Es ist eine Funktion zum Hochladen von Bildern implementiert.

- Starten Sie die Anwendung mit `docker compose up`.
- Öffnen Sie den Browser und navigieren Sie zu `http://127.0.0.1`
- Wählen Sie eine Grafik aus, die Sie hochladen möchten.

Die Webseite sollte Ihnen das hochgeladene Bilder anzeigen können.

Aufgabe 2: Laden Sie Schadcode hoch

Versuchen Sie eine Datei hochzuladen, die kein Bild, sondern Schadcode ist. Versuchen Sie die p0wny-shell unter <https://github.com/flozz/p0wny-shell/tree/master> hochzuladen.

Hinweis: Windows-Defender wird die p0wny-shell erkennen und löschen. Sie können eine Ausnahme eintragen oder phpbash von <https://github.com/Arrexel/phpbash/tree/master> nutzen.

- Können Sie den Schadcode auf dem Server ausführen? Erstellen Sie ein Screenshot.
- Wie haben Sie die Datei hochgeladen?

Aufgabe 3: Unzureichender Schutz

Nun hat der Entwickler der Webseite eine Verbesserung durchgeführt. Vor dem Upload wird lokal geprüft, ob die hochzuladende Datei wirklich ein Bild ist.

Beenden Sie die laufenden Docker Container mit `STRG+C` oder `docker compose down`.

Starten Sie die aktualisierte Anwendung mit den Befehlen

1. `docker compose -f docker-compose-js-security.yml build`
2. `docker compose -f docker-compose-js-security.yml up`

Versuchen Sie nun nochmals den Schadcode hochzuladen.

- Zeigen Sie ein Screenshot des Fehlers
- Zeigen Sie auf, welcher Teil für die Prüfung verantwortlich ist. Wird serverseitig oder clientseitig geprüft?

Aufgabe 4: Hacken Sie

Schauen Sie sich den Quelltext der Webseite an, um zu erkennen, wie und wohin Dateien hochgeladen werden. Benutzen Sie Wireshark, um den resultierenden HTTP Aufrufe mit seinen Inhalten zu sehen.

Nutzen Sie `curl`, um eine Datei direkt hochzuladen. Lesen Sie die manpage von `curl` (Eingabe von `man curl`) oder suchen Sie im Internet nach Tipps. Benutzen Sie auch hier wieder Wireshark, um den Browser-Aufruf und Ihren `curl`-Aufruf zu vergleichen.

- Zeigen Sie den Aufruf mit den Parametern von `curl`, der den Schadcode hochlädt.
- Zeigen Sie die Ausgabe von `curl`.

Aufgabe 5: Sichern Sie die Webseite Serverseitig ab

Es gibt mehrere Möglichkeiten die Anwendung serverseitig sicher zu gestalten. Sie können Apache umkonfigurieren oder die Datei `upload.php` erweitern. Denken Sie daran, dass Sie die Docker Container nach einer Änderung neustarten müssen.

- Zeigen Sie, wie Sie die Webseite sicher gemacht haben.
- Zeigen Sie den Aufruf des obigen `curl` Kommandos nochmals. Das Ergebnis sollte sein, dass der Upload verhindert wird.